AUDIT DE SÉCURITÉ · BTS SIO

Attaque par force brute

Exploitation d'une faille d'authentification sur DVWA pour comprendre comment la corriger.

Cible : DVWA · niveau Low · Burp Suite · Kali Linux

Thomas Montout

POST /vulnerabilities/brute/ 302

username = §admin§

password = §password§

Combinaison trouvée par réponse de longueur différente.

CONTEXTE

Contexte et objectifs

OBJECTIF

Démontrer l'exploitation d'une faille d'authentification sur DVWA pour comprendre comment la corriger.

DÉMARCHE EN 4 TEMPS

- Reconnaissance : énumérer les utilisateurs
- Interception de la requête d'authentification
- Attaque automatisée par dictionnaire
- Analyse puis recommandations de sécurité

NIVEAU DE LA CIBLE

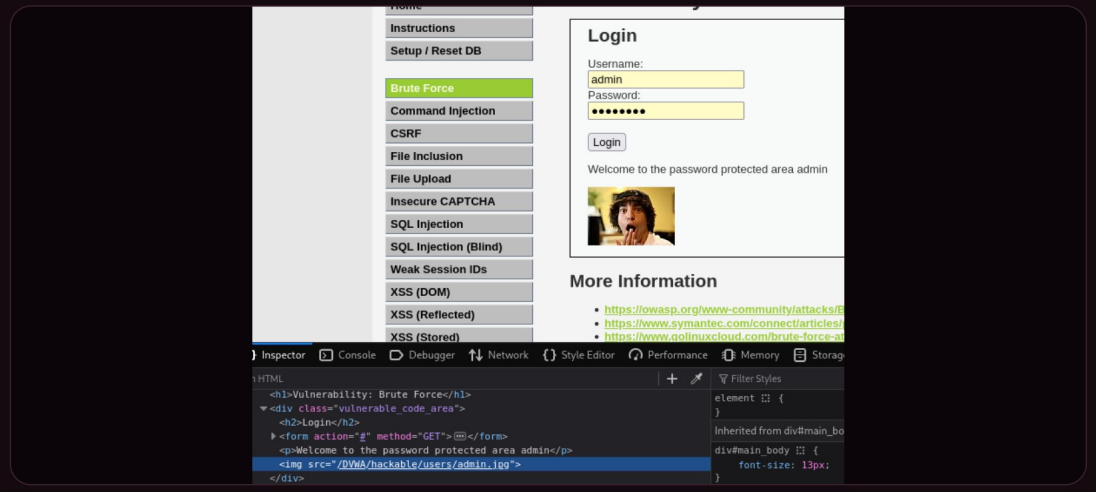
Low

Aucune protection : ni limitation, ni jeton anti-rejeu

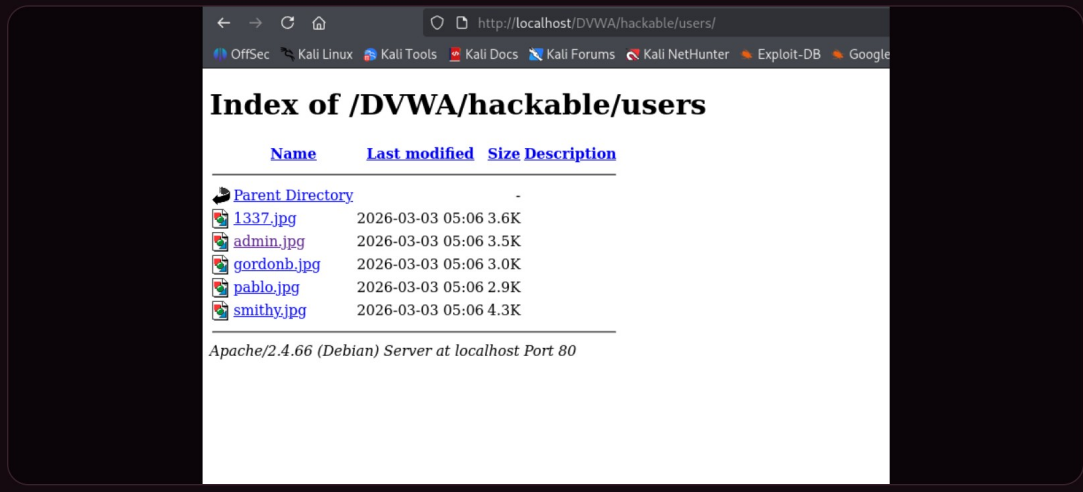
⚠ Exercice mené uniquement en local, dans la VM Kali isolée du laboratoire DVWA.

ÉTAPE 01 · RECONNAISSANCE

Une fuite d'informations livre les comptes



L'inspecteur révèle le chemin de l'avatar : /DVWA/hackable/users/admin.jpg

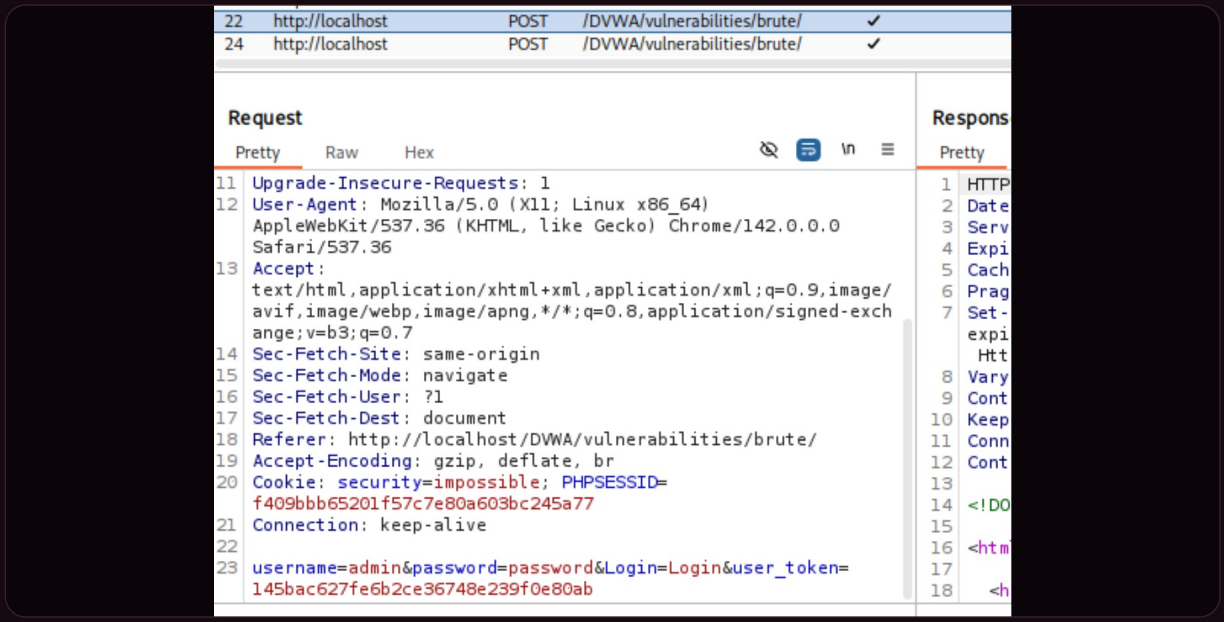


Le dossier parent s'affiche : **Directory Listing**

```
5 comptes valides énumérés 1337 · admin · gordonb · pablo · smithy
```

ÉTAPE 02 · INTERCEPTION

La requête passe par Burp Suite



Requête POST capturée dans l'onglet HTTP history

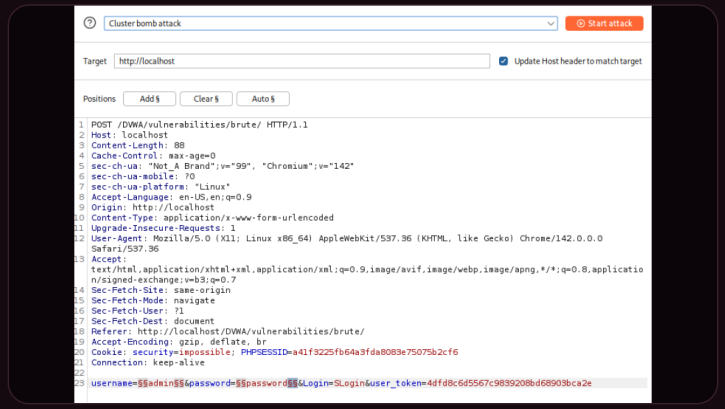
CORPS DE LA REQUÊTE

```
username=admin
password=password
Login=Login
```

> ⚠ Les identifiants transitent en clair : l'échange n'est pas chiffré.

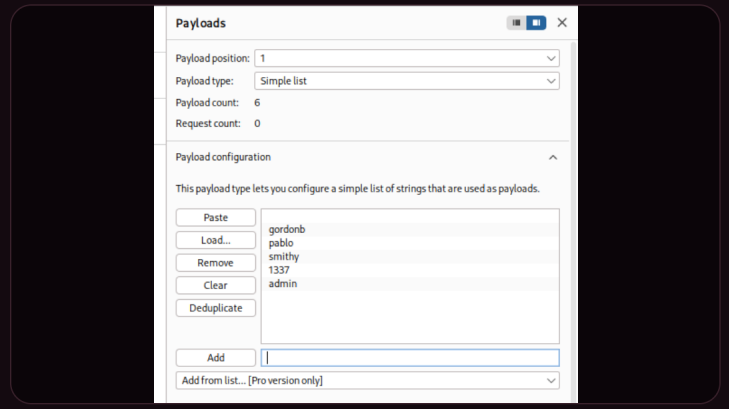
ÉTAPE 03 · ATTAQUE AUTOMATISÉE

Intruder croise comptes et mots de passe



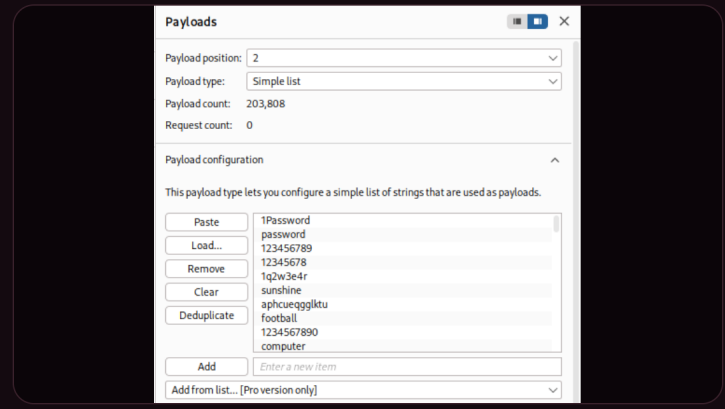
POINTS D'INJECTION

Marqueurs § sur username et password, mode **Cluster bomb**



PAYLOAD 1 · UTILISATEURS

Les 5 comptes énumérés en reconnaissance



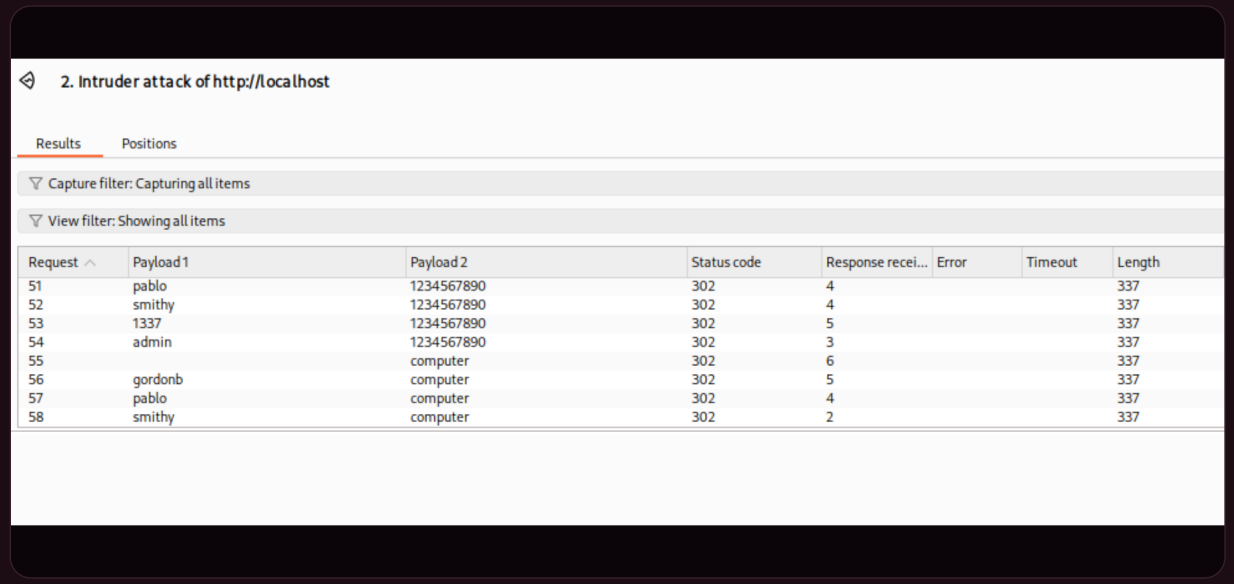
PAYLOAD 2 · MOTS DE PASSE

Dictionnaire de mots de passe probables (type rockyou)

Le mode Cluster Bomb teste toutes les combinaisons entre les deux listes.

RÉSULTATS

Repérer la connexion réussie



Request	Payload 1	Payload 2	Status code	Response recei...	Error	Timeout	Length
51	pablo	1234567890	302	4			337
52	smithy	1234567890	302	4			337
53	1337	1234567890	302	5			337
54	admin	1234567890	302	3			337
55		computer	302	6			337
56	gordonb	computer	302	5			337
57	pablo	computer	302	4			337
58	smithy	computer	302	2			337

Intruder génère une requête par combinaison et tabule les réponses.

LENGTH

Une réponse de taille différente trahit une authentification réussie.

STATUS CODE

La redirection 302 confirme la combinaison valide.

CONCLUSION · COMMENT CORRIGER

Ce que la faille apprend à corriger

Freiner les tentatives

Verrouillage après N échecs, temporisation, CAPTCHA, double authentification

Durcir les accès

Mots de passe forts, jeton anti-rejeu par requête, HTTPS, pas de message distinguant les erreurs

Fermer les fuites

Désactiver le Directory Listing, retirer les chemins exposés, ne pas révéler les comptes valides

Sur DVWA, ces mesures correspondent aux niveaux Medium, High puis Impossible.